Dukaan Connect — Privacy and security choices

Track A: Project Udyam Digital | Submission note | 8 November 2026

The case asks for data minimisation, consent before KYC, masked identifiers and a document-retention period. This note describes the implemented prototype and its production boundaries. All supplied businesses, people and identifiers are synthetic.

1. Collect for a specific purpose

Discovery uses business type, staff, locations, city and service needs; GSTIN is optional. Checkout needs a contact number and service address. KYC follows the chosen GST, Udyam or shop-licence route, with address/signatory proof. SIM users supply their own name and number. We do not request biometrics, card details or a UPI PIN. Uploaded images can contain extra personal information; redaction needs review before real-data use.

2. Consent before KYC

A notice in the selected language separates verification/service delivery from optional AI document reading, order updates and marketing. Optional choices start off. The ledger records purpose, notice version, language, channel and time. Uploads and KYC require live verification consent. Tracker withdrawal blocks subsequent processing for that purpose.

3. Mask identifiers; restrict access

GSTIN, Udyam and phone values become random vault tokens in service flows. UI, logs and model history apply identifier masking. Detokenisation checks actor, purpose and order consent; allowed/refused attempts are audited. Partners see their own work; risky reviewer overrides need two people. Pattern masking does not anonymise all free text.

4. Encrypt sensitive records

Vault values and document-photo files use AES-256-GCM with a random data key per record/file and authenticated key wrapping. The deployed master key comes from Secret Manager; direct Cloud KMS wrapping is a production integration. The public service uses HTTPS. Business metadata, masked transcripts and extracted fields are not all application-encrypted.

5. Disclose AI and voice processing

The chat model receives masked history and business context. Local Tesseract/OpenCV is the first document reader. Separate opt-in permits Anthropic to read business-document photos, never signatory IDs; the notice discloses processing outside India. Calls send clips to Sarvam before transcript masking, and send reply text for speech; browser speech is the fallback. Input recordings are not retained as application records; generated speech can be cached in memory. Vendor retention/location require contractual verification.

6. Retain only for a stated window

Photos expire 30 days after upload; an hourly task deletes files and their wrapped keys while the service runs. Open advisor sessions inactive for 30 days have history/profile cleared and associated tokens shredded. Quoted sessions, order records, extracted fields and backups are not covered by a blanket 30-day purge. Production needs a full schedule, durable cleanup and notice wording aligned with the upload-based deadline.

7. Give owners control; verify safeguards

Order-access links support data viewing/export, consent withdrawal, access history and erasure of order documents/core identifier keys. Other records need lifecycle review before promising complete erasure. Tests exercise consent gates, masking, encryption, purpose-bound access, crypto-shredding and excluding IDs from vision AI. Signed staff tokens, rate limits and webhook-signature checks add protection.

8. Separate prototype from production

Registries, DigiLocker, telecom verification, masked calling and payments are mocked/test-mode. Real-data rollout needs processor/transfer agreements, image/free-text minimisation, access-link and backup/key review, and operational grievance/breach processes under applicable DPDP and telecom requirements. This is a design note, not a compliance certification.

Basis: Airtel_SYNC_Case.pdf pp. 3–4; data-pack README “Privacy expectations”; implementation in api/app/privacy, api/app/kyc, api/app/voice and api/app/routers.

Reference: MeitY: DPDP Rules, 2025 — official Gazette. Commencement is phased; confirm the provisions applicable at production launch.